Incident Response Plan

Version: 1.0

Effective Date: 08. December 2025

Owner: Governance, Risk and Compliance (GRC) Manager

1. Preparation

1.1. CSIRT Structure and Composition

- **Core Team:**
  These team are the central actors in incident response actions. Inclusive of:
  - Incident Response Manager (Chair): Leads and guides all Incident Response Action once CSIRT Plan is activated.
  - GRC Manager: Subject Matter Expert (SME) on policies and procedure, to advice on what policy dictates.
  - Lead Security Analyst: Subject Matter Expert on Security, guides security response in consultation with the chair.
  - Forensics Specialist: SME on matters digital forensics and evidence preservation techniques.
  - IT Operations Lead: SME and partner on ICT response, tools and backup operation activation.
- **Extended Team (as needed or on consultation basis):**
  Internal Subject matter experts to coordinate with the core team as required:
  - Legal Counsel: SME, Legal guide.
  - Data Privacy Officer: SME, Data privacy requirements and steps.
  - Human Resources: SME, Staff direction, coordination and safety.
  - Communications: SME, Communication internal and external.
  - Application Owners: SME, individual apps and systems, critical in impact assessment and restoration confirmation.
- **External Resources (as Per SLA):**
  Guided by Service Level Agreement, activated as required based on incident level.
  - Managed Security Service Provider (MSSP): Security Partners and escalation for all incidents per Service Level Agreement (SLA). Activated guided per SLA in consultation with security lead and IT operations lead.
  - External Forensics Firm: Collaborate with Forensic Specialist based on SLAs,
  - Cyber Insurance Provider: Consultants and activation process guided by SLA in consultation with GRC Manager.

1.2. Tools and Resources

Tool/Resource	Purpose
SIEM	Security Information and Event Management
IDS/IPS	Intrusion Detection/Prevention System
EDR	Endpoint Detection and Response
Forensic Software	Analysis and Digital Forensics
Secure Communication Platform	dedicated channel, centralized communication
Incident Response Ticketing System	Main channel for Incident notification and escalation

1.3. Training and Awareness Program

- **CSIRT Training:**
  - Annual incident response tabletop exercises.
  - Targeted trainings on current existing security solutions and systems.
  - Specialized training in forensics, malware analysis, etc.
- **Employee Awareness:**
  - Annual security awareness training.
  - Regular trainings on policies and procedures.
  - Regular phishing simulations.

1.4. Communication Infrastructure

- **Primary Communication:** IT Helpdesk System
- **Out-of-Band Communication:** personal phone and email addresses, conference call bridge - to be used if primary systems are compromised.

2. Detection and Analysis

2.1. Detection Sources and Methods

- SIEM alerts
- IDS/IPS alerts
- EDR alerts
- Antivirus alerts
- User reports (via Help Desk)
- Third-party notifications (e.g., from law enforcement, researchers)

2.2. Initial Triage Procedures

1. Receive suspected incident report.
2. Create a new incident ticket.
3. Validate the report - is it a true positive?
4. Assign an initial severity level.
5. Escalate to the Incident Response Manager.

2.3. Incident Analysis Framework

1. **Scope the incident:** Identify all affected systems and data.
2. **Identify the attack vector:** How did the attacker get in?
3. **Collect and preserve evidence:** Follow chain of custody procedures.
4. **Analyze logs, network traffic, and system images.**
5. **Document all findings.**

2.4. Documentation Requirements

- Incident ticket with all actions taken.
- Initial assessment report.
- Evidence logs (chain of custody).
- Forensic analysis report.

3. Containment, Eradication, and Recovery

3.1. Containment Strategies

- **Short-Term:**
  - Isolate affected systems from the network.
  - Disable compromised user accounts.
  - Block malicious IP addresses.
- **Long-Term:**
  - Move affected systems to a quarantine VLAN.
  - Implement temporary firewall rules.

3.2. Eradication Procedures

1. Remove malware from all affected systems.
2. Reset all compromised credentials.
3. Patch all identified vulnerabilities.
4. Rebuild systems from a known good image if necessary.

3.3. Recovery Processes

1. Restore data from backups.
2. Validate that systems are clean and fully functional.
3. Return systems to production.
4. Implement enhanced monitoring.

3.4. Business Continuity Integration

- If a critical incident occurs, the Business Continuity Plan (BCP) will be activated.
- The CSIRT will work with the BCP team to prioritize recovery efforts based on business impact.

4. Post-Incident Activity

4.1. Lessons Learned Process

- A post-incident review will be held within two weeks of incident closure.
- Participants will include the CSIRT, relevant business stakeholders, and executive leadership.

- The goal is to identify what went well, improvement opportunities, and the root cause of the incident.

4.2. Root Cause Analysis

- Use the “5 Whys” to identify the underlying cause of the incident. To be customized for each incident.

4.3. Improvement Recommendations

- All lessons learned will be translated into actionable recommendations.
- Each recommendation will be assigned an owner and a due date.
- Progress will be tracked in the GRC tool.

4.4. Metrics and Reporting

- The GRC Manager will produce a quarterly incident response report for executive leadership.
- The report will include key metrics such as MTTD, MTTR, and incident volume.